

INFORME TÉCNICO DE VULNERABILIDADES

“Sistema REGINSA”

<https://reginsaqa.sunedu.gob.pe/>

SUNEDU

02 marzo de 2026

Contenido

1. Introducción	3
2. Alcance del Proyecto	3
3. Herramientas utilizadas	3
4. Hallazgo de Vulnerabilidades	3
5. Detalle de Vulnerabilidades Identificadas:	3
Las pruebas mostradas solo son unos ejemplos de los hallazgos encontrados, las soluciones implementadas deben ser desplegadas a toda la aplicación. ¡Error! Marcador no definido.	
Escaneo dinámico	12
Escaneo dinámico	13

Informe Técnico

1. Introducción

La Oficina de Tecnologías de la Información/ Unidad de Infraestructura Tecnológica de la “SUNEDU”, pretende asegurar los niveles de seguridad de los aplicaciones web nuevos o en producción, módulos nuevos del Sistema de Información Universitaria - SIU, y los Servicios web (en inglés “Web Service”) de la SUNEDU, teniendo en consideración que están expuestos a riesgos de ataques informáticos desde la red de externa (internet) y la red interna de la SUNEDU, con el objeto de asegurar la disponibilidad, confidencialidad e integridad de la información requerida por los administrados y procesos internos de la entidad.

2. Alcance del Proyecto

<https://reginsaqa.sunedu.gob.pe/>

3. Herramientas utilizadas

Para el desarrollo de las pruebas se utilizaron diversas herramientas, entre las cuales se incluyen las siguientes

- Zaproxy - OWASP ZAP

4. Hallazgo de Vulnerabilidades

Se utilizaron herramientas de escaneo automatizado para la identificación rápida de fallas comunes, complementadas con la intervención manual

5. Detalle de Vulnerabilidades Identificadas:

ITEM	ID	TAG	Critico	TITULO	NOMBRE CUS:
	23889		3 - Medium	N°12 Denegacion de servicios por inundacion de peticiones MEDIO	OTI- USITD\Seguridad
				<u>Escaneo dinámico</u> https://reginsaapiqa.sunedu.gob.pe	OTI- USITD\Seguridad
				Escaneo dinámico reginsaqa.sunedu.gob.pe	OTI- USITD\Seguridad

ITEM 3 - 23889	
NOMBRE CUS:	USITD\Seguridad
TITULO:	N°12 Denegacion de servicios por inundación de peticiones MEDIO
TIPO:	Unknown

TAG:

DESCRIPCION:

TIPO DE APLICATIVO: WEB
RIESGO:

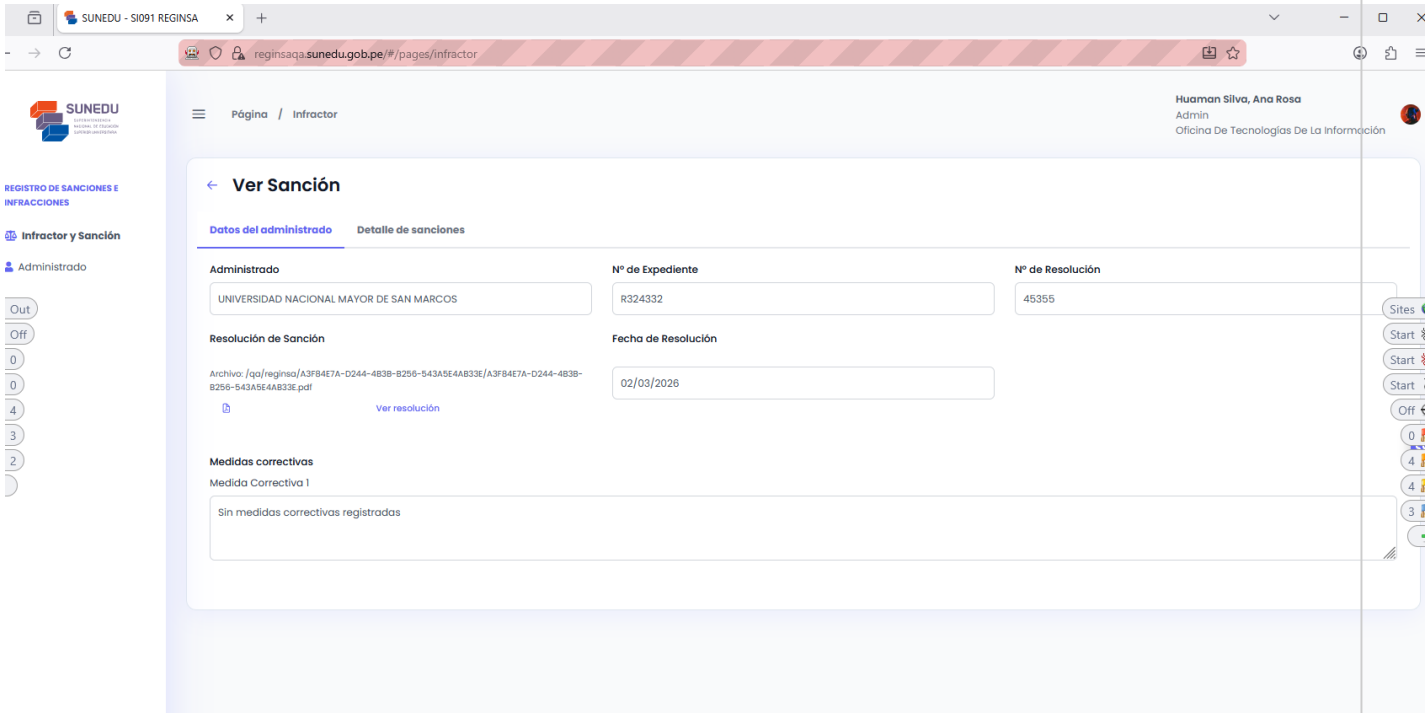
VALORACIÓN DEL RIESGO					
Valor del Activo	2	Facilidad de explotación	MEDIO	Impacto	4
PROBABILIDAD DEL RIESGO	BAJO	MEDIO		ALTO	
		⬆			
RIESGO PONDERADO (IMPACTO)	BAJO	MEDIO		ALTO	
		4			
		⬆			

DESCRIPCIÓN:

Ataques del tipo flood, permiten a un atacante a aprovechar dicha brecha de seguridad para ocasionar una denegación de servidor a través de número de solicitudes de subidas de archivos, escritura en base de datos y espacio en el servidor. Denegación de servicios afectando la disponibilidad de la información.

EVIDENCIA:
Caso 1:

Se registra una sanción , seleccionando al administrado.



Ver Sanción

Datos del administrado | **Detalle de sanciones**

Administrado: UNIVERSIDAD NACIONAL MAYOR DE SAN MARCOS

Nº de Expediente: R324332

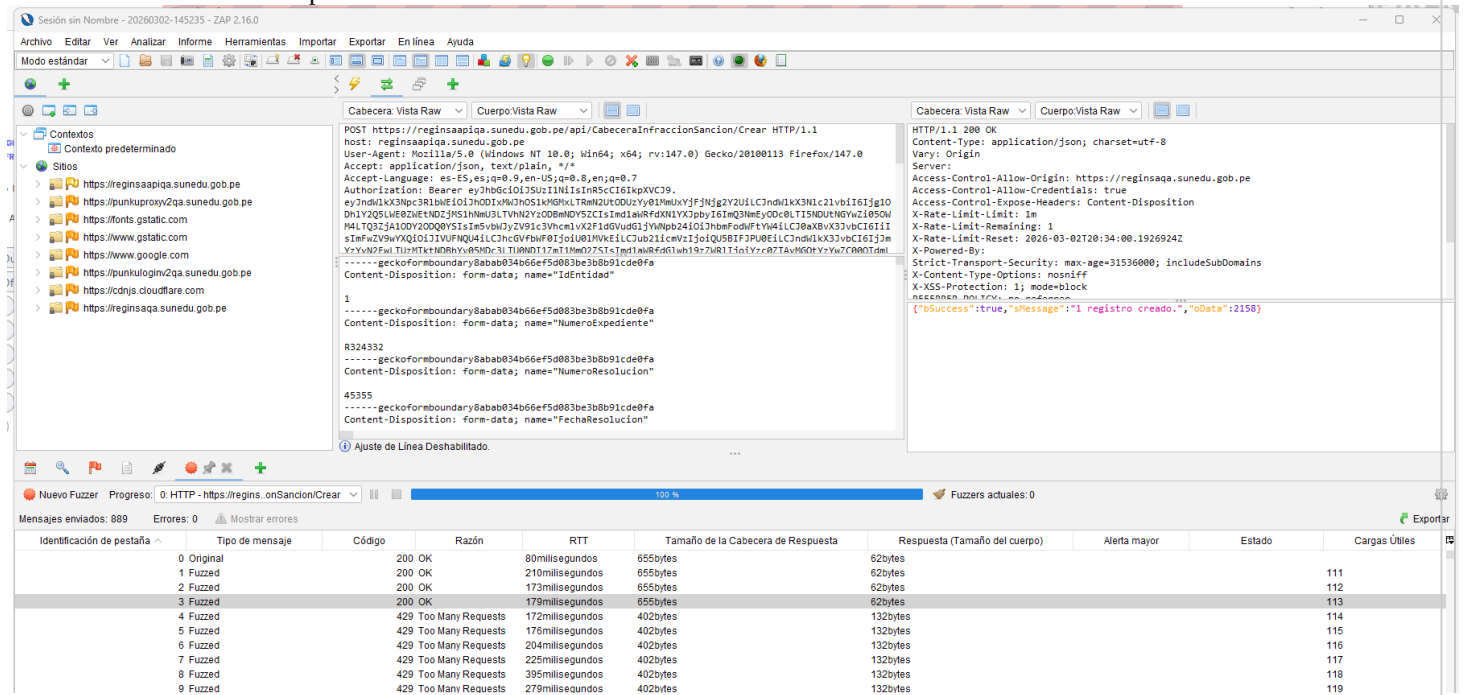
Nº de Resolución: 45355

Resolución de Sanción: Archivo: [qql/reginsa/A3F84E7A-D244-483B-8256-543A5E4AB33E/A3F84E7A-D244-483B-8256-543A5E4AB33E.pdf]

Fecha de Resolución: 02/03/2026

Medidas correctivas: Medida Correctiva 1: Sin medidas correctivas registradas

Se realizó una enumeración para crear 888 sanciones



POST https://reginsaapiqa.sunedu.gob.pe/api/CabeceraInfraccionSancion/Crear HTTP/1.1

host: reginsaapiqa.sunedu.gob.pe

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:147.0) Gecko/20100113 Firefox/147.0

Accept: application/json, text/plain, */*

Accept-Language: es-ES,es;q=0.9,en-US;q=0.8,en;q=0.7

Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM5OTIxNDQ1IiwiaWF0IjoiMTY2OTQ1MjM5OTIxNDQ1IiwiaWF0IjoiMTY2OTQ1MjM5OTIxNDQ1InQ9

Content-Type: application/json

Content-Disposition: form-data; name="NumeroExpediente"

Content-Disposition: form-data; name="NumeroResolucion"

Content-Disposition: form-data; name="FechaResolucion"

Response: HTTP/1.1 200 OK
Content-Type: application/json; charset=utf-8
Vary: Origin
Server: [redacted]
Access-Control-Allow-Origin: https://reginsa.sunedu.gob.pe
Access-Control-Allow-Credentials: true
Access-Control-Expose-Headers: Content-Disposition
X-Rate-Limit-Limit: 1m
X-Rate-Limit-Remaining: 1
X-Rate-Limit-Reset: 2026-03-02T20:34:00.1926924Z
X-Powered-By: [redacted]
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
{"success":true,"message":"1 registro creado","data":{"id":12158}}

Identificación de pestaña	Tipo de mensaje	Código	Razón	RTT	Tamaño de la Cabecera de Respuesta	Respuesta (Tamaño del cuerpo)	Alerta mayor	Estado	Cargas Útiles
0 Original	200 OK	200 OK	80milisegundos	655bytes	62bytes				
1 Fuzzed	200 OK	200 OK	210milisegundos	655bytes	62bytes				111
2 Fuzzed	200 OK	200 OK	173milisegundos	655bytes	62bytes				112
3 Fuzzed	200 OK	200 OK	179milisegundos	655bytes	62bytes				113
4 Fuzzed	429 Too Many Requests	429 Too Many Requests	172milisegundos	402bytes	132bytes				114
5 Fuzzed	429 Too Many Requests	429 Too Many Requests	176milisegundos	402bytes	132bytes				115
6 Fuzzed	429 Too Many Requests	429 Too Many Requests	204milisegundos	402bytes	132bytes				116
7 Fuzzed	429 Too Many Requests	429 Too Many Requests	225milisegundos	402bytes	132bytes				117
8 Fuzzed	429 Too Many Requests	429 Too Many Requests	395milisegundos	402bytes	132bytes				118
9 Fuzzed	429 Too Many Requests	429 Too Many Requests	279milisegundos	402bytes	132bytes				119

Se obtuvieron solo 3 registro de sanciones en el sistema.

[illegible]



SUNEDU
Sistema Nacional de Evaluación y
Control de la Gestión

REGISTRO DE SANCIONES E INFRACCIONES

Infractor y Sanción

Administrado

Fecha Registro

Expediente

Resolución

Todos

Limpiar

Buscar

+ Expandir Todo

+ Registrar Sancionar

Exportar xls

#	Acciones	Administrado	Nº de Expediente	Nº de Resolución	F. Resolución	F. Registro	F. Modificación	Nº Reconsideración	F. Recons.
> 1	   	UNIVERSIDAD NACIONAL MAYOR DE SAN MARCOS	R324332	45355	02/03/2026	02/03/2026			
> 2	   	UNIVERSIDAD NACIONAL MAYOR DE SAN MARCOS	R324332	45355	02/03/2026	02/03/2026			
> 3	   	UNIVERSIDAD NACIONAL MAYOR DE SAN MARCOS	R324332	45355	02/03/2026	02/03/2026			
> 4	   	UNIVERSIDAD NACIONAL DEL CALLAO	EXP Nº 1413-2026	RES Nº 7129-2026	02/01/2026	02/03/2026			
> 5	   	UNIVERSIDAD PRIVADA 67950 S.C.R.L	EXP Nº 2150-2025	RES Nº 8569-2025	22/08/2025	02/03/2026			
> 6	   	MARINA DE GUERRA DEL PERU	EXP Nº 272-2025	RES Nº 103-2025	02/11/2025	02/03/2026			
> 7	   	UNIVERSIDAD PERUANA DE INTEGRACION GLOBAL	EXP Nº 3769-2025	RES Nº 5399-2025	04/12/2025	02/03/2026			
> 8	   	CONSORCIO NACIONAL 42059 ASOCIACION CIVIL	EXP Nº 7062-2026	RES Nº 2834-2026	05/01/2026	02/03/2026			
> 9	   	CORPORACION PARTICULAR 89455 INVERSIONES S.A.C.	EXP Nº 6917-2025	RES Nº 4725-2025	22/07/2025	02/03/2026			

Resultado:

Se está controlando la creación de sanciones a un máximo 3 .
Igualmente se debe configurar la creación de otros objetos como infracción.
En el Caso 1 se da conformidad

Caso 2:

Se registra la infracción:

Se realizó una enumeración para crear 9999 infracciones

Se observa que cada 25 solicitudes de registro de una infracción se registra una infracción. Aproximadamente se registraron 450 registros de infracciones.

Aquí sale mensaje de error y no registra

Mensaje de error.

System.Exception: Error al guardar detalle infracción: Error en SP: La transacción (id. de proceso 67) quedó en interbloqueo en bloqueo recursos con otro proceso y fue elegida como sujeto del interbloqueo. Ejecute de nuevo la transacción. (Línea: 158)

```
---> System.Exception: Error en SP: La transacción (id. de proceso 67) quedó en interbloqueo en
bloqueo recursos con otro proceso y fue elegida como sujeto del interbloqueo. Ejecute de nuevo la
transacción. (Línea: 158)
```

```

at
Sunedu.BackEnd.Reginsa.Infrastructure.Repository.DetalleInfraccionSancionRepository.Create(Detalle
InfraccionSancionEntity input) in /var/lib/jenkins/workspace/OA/SI091 REGINSA BACKEND-

```


1

qa/04Infrastructure/Sunedu.BackEnd.Reginsa.Infrastructure.Repository/DetalleInfraccionSancionRepository.cs:line 48

--- End of inner exception stack trace ---

at

Sunedu.BackEnd.Reginsa.Infrastructure.Repository.DetalleInfraccionSancionRepository.Create(DetalleInfraccionSancionEntity input) in /var/lib/jenkins/workspace/QA/SI091_REGINSA_BACKEND-qa/04Infrastructure/Sunedu.BackEnd.Reginsa.Infrastructure.Repository/DetalleInfraccionSancionRepository.cs:line 55

at

Sunedu.BackEnd.Reginsa.Application.Command.DetalleInfraccionSancion.DetalleInfraccionSancionCommandHandlers.Handle(DetalleInfraccionSancionCreateCommand request, CancellationToken cancellationToken) in /var/lib/jenkins/workspace/QA/SI091_REGINSA_BACKEND-qa/02Application/Sunedu.BackEnd.Reginsa.Application.Command/DetalleInfraccionSancion/DetalleInfraccionSancionCommandHandlers.cs:line 52

at

Sunedu.BackEnd.Reginsa.Rest.Controllers.DetalleInfraccionSancionController.Crear(DetalleInfraccionSancionCreateCommand command) in /var/lib/jenkins/workspace/QA/SI091_REGINSA_BACKEND-qa/01Distribution/Sunedu.BackEnd.Reginsa.Rest/Controllers/DetalleInfraccionSancionController.cs:line 26

at

Microsoft.AspNetCore.Mvc.Infrastructure.ActionMethodExecutor.TaskOfIActionResultExecutor.Execute(ActionContext actionContext, IActionResultTypeMapper mapper, ObjectMethodExecutor executor, Object controller, Object[] arguments)

at

Microsoft.AspNetCore.Mvc.Infrastructure.ControllerActionInvoker.<InvokeActionMethodAsync>g__Awaited|12_0(ControllerActionInvoker invoker, ValueTask`1 actionResultValueTask)

at

Microsoft.AspNetCore.Mvc.Infrastructure.ControllerActionInvoker.<InvokeNextActionFilterAsync>g__Awaited|10_0(ControllerActionInvoker invoker, Task lastTask, State next, Scope scope, Object state, Boolean isCompleted)

at

Microsoft.AspNetCore.Mvc.Infrastructure.ControllerActionInvoker.Rethrow(ActionExecutedContextSealed context)

at Microsoft.AspNetCore.Mvc.Infrastructure.ControllerActionInvoker.Next(State& next, Scope& scope, Object& state, Boolean& isCompleted)

at

Microsoft.AspNetCore.Mvc.Infrastructure.ControllerActionInvoker.<InvokeInnerFilterAsync>g__Awaited|13_0(ControllerActionInvoker invoker, Task lastTask, State next, Scope scope, Object state, Boolean isCompleted)

at

Microsoft.AspNetCore.Mvc.Infrastructure.ResourceInvoker.<InvokeFilterPipelineAsync>g__Awaited|20_0(ResourceInvoker invoker, Task lastTask, State next, Scope scope, Object state, Boolean isCompleted)

at

Microsoft.AspNetCore.Mvc.Infrastructure.ResourceInvoker.<InvokeAsync>g__Awaited|17_0(ResourceInvoker invoker, Task task, IDisposable scope)

at

Microsoft.AspNetCore.Mvc.Infrastructure.ResourceInvoker.<InvokeAsync>g__Awaited|17_0(ResourceInvoker invoker, Task task, IDisposable scope)

at Microsoft.AspNetCore.Authorization.AuthorizationMiddleware.Invoke(HttpContext context)

at Microsoft.AspNetCore.Authentication.AuthenticationMiddleware.Invoke(HttpContext context)

1
at AspNetCoreRateLimit.RateLimitMiddleware`1.Invoke(HttpContext context) in
C:\Users\User\Documents\Github\AspNetCoreRateLimit\src\AspNetCoreRateLimit\Middleware\RateLimitMid
dleware.cs:line 124

at Microsoft.AspNetCore.Diagnostics.DeveloperExceptionPageMiddlewareImpl.Invoke(HttpContext
context)

HEADERS

=====

Accept: application/json, text/plain, */*

Accept-Language: es-ES;es;q=0.9,en-US;q=0.8,en;q=0.7

Authorization: Bearer

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJndWlkX3Npc3RlbWEiOiJhODIxMWJhOS1kMGxLTmN2U0UzYy01MmUxYjFjNjg2Y2UiLCJndWlkX3Nlc2lubiI6Ijg1ODh1Y2Q5LWE0ZWETNDZjMS1hNmU3LTVhN2YzODBmNDY5ZCI6Imd1aWRfdXN1YXJpbYi6ImQ3NmEyODc0LTl5NDU0NGYwZi05OWM4LTQ3ZjA1ODY2ODQ0YSIsIm5vbWJyZV91c3Vhcm1vX2F1dGVudGljYWNpb24iOiJhbmFodWFtYW4iLCJ0aXBvX3JvbCI6IiIsImFwZW9wYXQiOiJ1VUFNQ4iLCJhcGVfbWF0IjoIjoiU01MVkEiLCJub21icmVzIjoIQU5BIFJPU0EiLCJndWlkX3JvbCI6IjJmYzYyN2EwLTUzMTktNDZhYy05MDc3LTU0NDI1ZmI1MmQ2ZSI6Imd1aWRfdGlwb19zZWRLIjoIYzZ0ZTAyMGQ0YzYwZC00OTdmLWE4Y2M0Njg0MDk0YmRmNjU2IiwiaXN1bWVudC3JfZGVmZW50byI6IiRydWUiLCJ1YmY0IjE3NzI0ODEyMjc5ImV4cCI6MTc3MjQ0NDgzMiwiawWF0IjoXNzcyNDgxMjMyLCJpc3MiOiJodHRwczovL3B1bmt1cHJveH1xYS5zdW51ZHUuZ29iLnB1LyIsImF1ZCI6Imh0dHBzOi8vcHVua3Vwcm94eXhLnN1bmVkdS5nb2IucGUvIn0.dzHjthFaJH0ToxCGWptQ3eLmEDICqxxZzQr8vGIVMYuWak8vnDqNwYkgWarryZ9cCyZ4JkyrU7qN_Zr1rWLAzFOCzyIfYnKWnjKjp-onjQgLq5TQtI67WxCcFfiegq_LTVNSPCT93ILb80LIbW7Vmfmqjzj4mXBQVNLmNnqfekyPCVjQfI_K3Jty9bkYPxbptQwlatkjbKJz1eN7-TSiJXW9rOym-vRL_xbFJxeNf_oj41zbGx-VUKARlv24JkLWq8WXsai9oguJlFs47iqUNdvKRHSBULbPhC7zym9o-et7s0LuLqXzzV87DGBp4Bwy8iKsKxaACaw0r34FBFjevraoc2U00QQdK5M_A9upBFzSIUAMQM1ZCO3ddjRuuvvu39EFRcHJBwTNlegmfqZx1yyLBx8wp0UcGulH8ZQxANr9K6BUXJm5BSypBRi363pVe_6De1-N6VNamhhGiHsn6x2fSdAQ4-VUhVyPKFXi4X1pvQ5XQuJrwyvirp_ZzGHWJ

Connection: keep-alive

Content-Length: 518

Content-Type: application/json

Host: reginsaapiqa.sunedu.gob.pe

Referer: https://reginsaqa.sunedu.gob.pe/

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:147.0) Gecko/20107589 Firefox/147.0

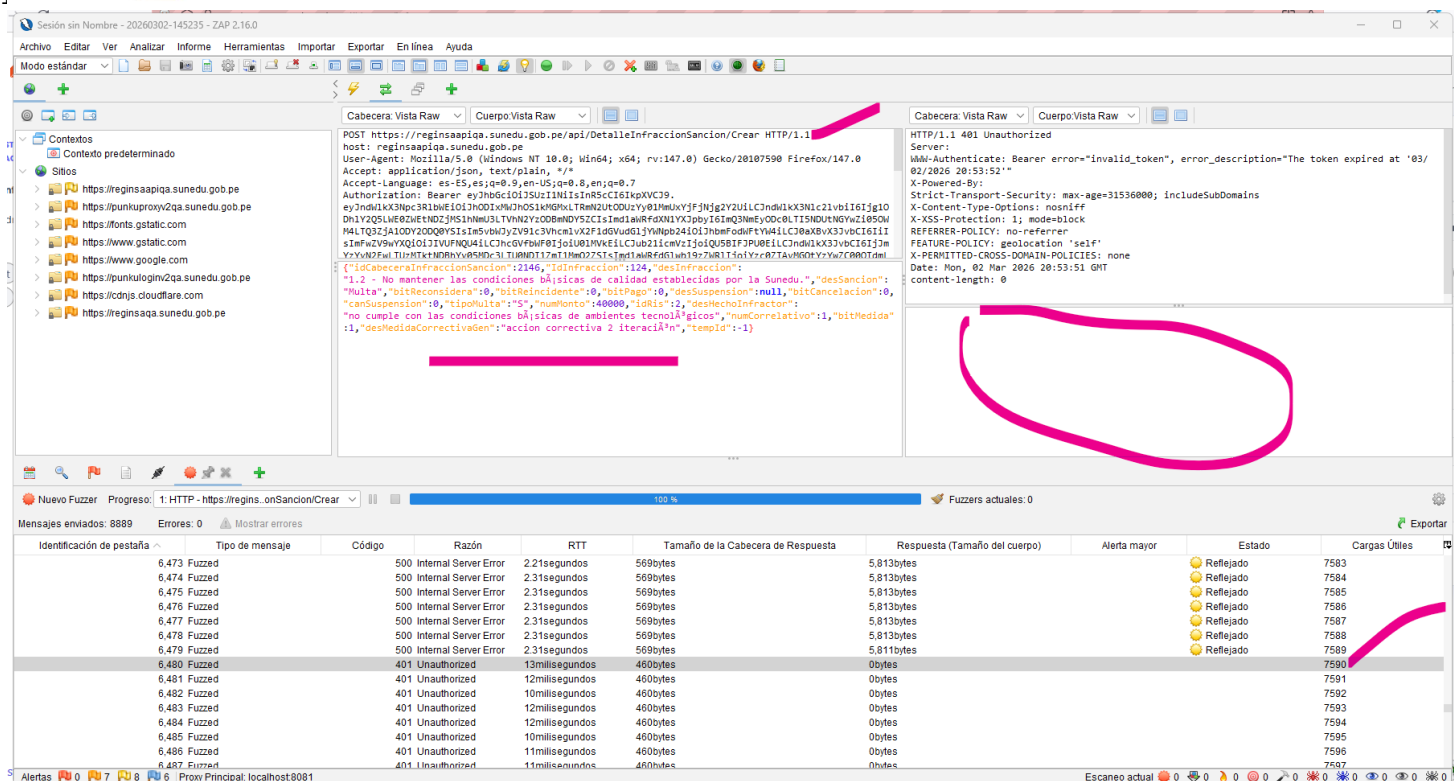
Origin: https://reginsaqa.sunedu.gob.pe

Sec-Fetch-Dest: empty

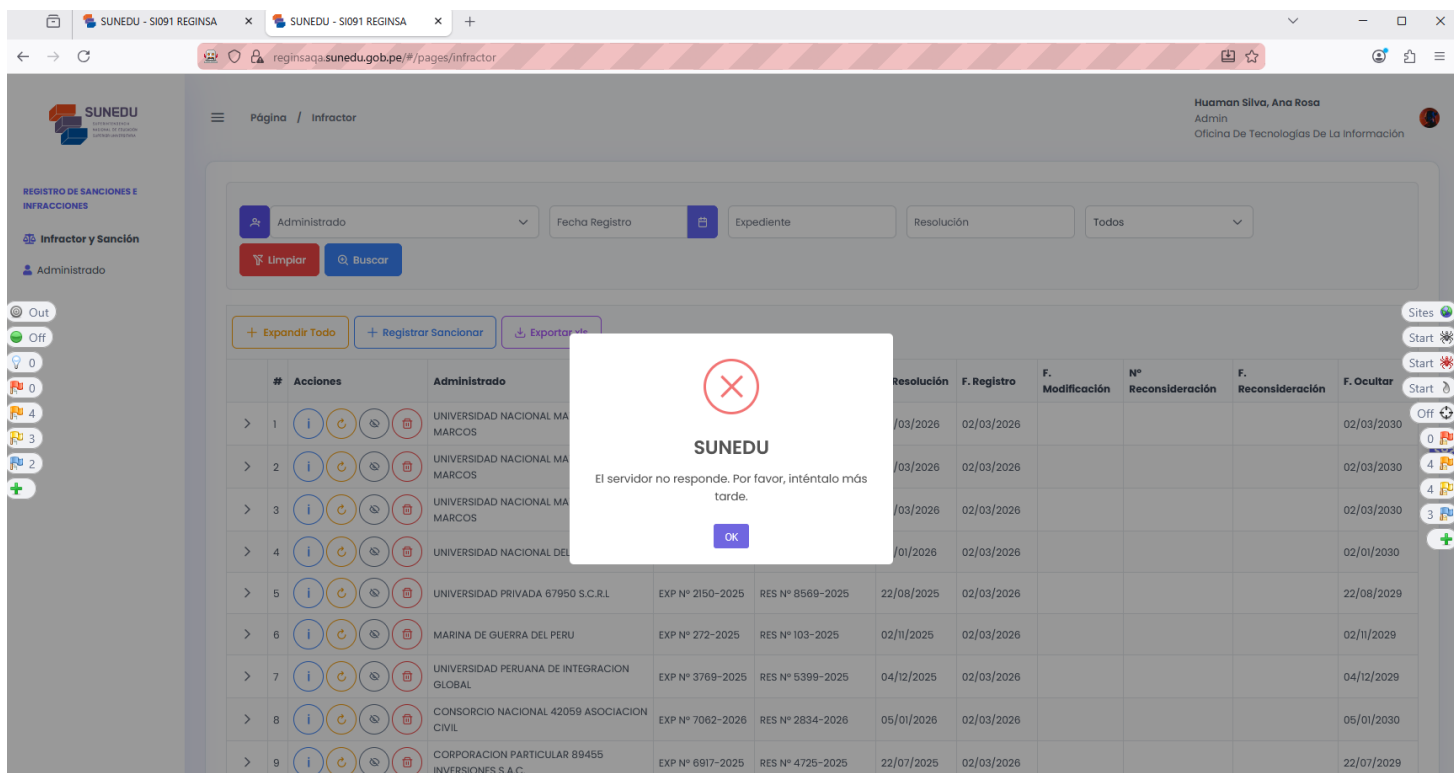
Sec-Fetch-Mode: cors

Sec-Fetch-Site: same-site

Luego en la petición 7590, ya se tiene respuesta del servidor ni se registra



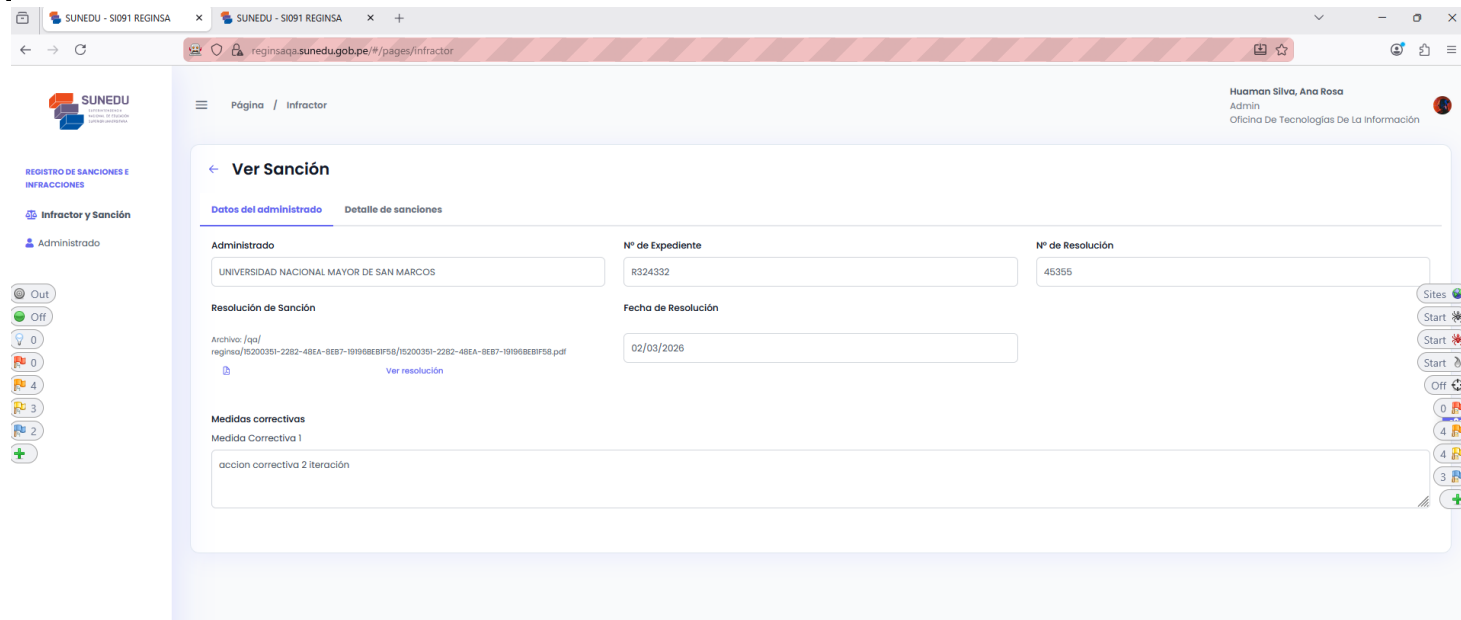
Al ingresar a la aplicación, se vio que no devolvía datos
Luego salió este mensaje:



Luego de que se terminó la petición masiva de 9999 solicitudes de creación de infracciones
Se restableció el servicio y se ingresó de nuevo con el usuario y contraseña.

Se observa que se registraron 425 infracciones
No se da conformidad

1



Ver Sanción

Datos del administrado | Detalle de sanciones

Administrado: UNIVERSIDAD NACIONAL MAYOR DE SAN MARCOS

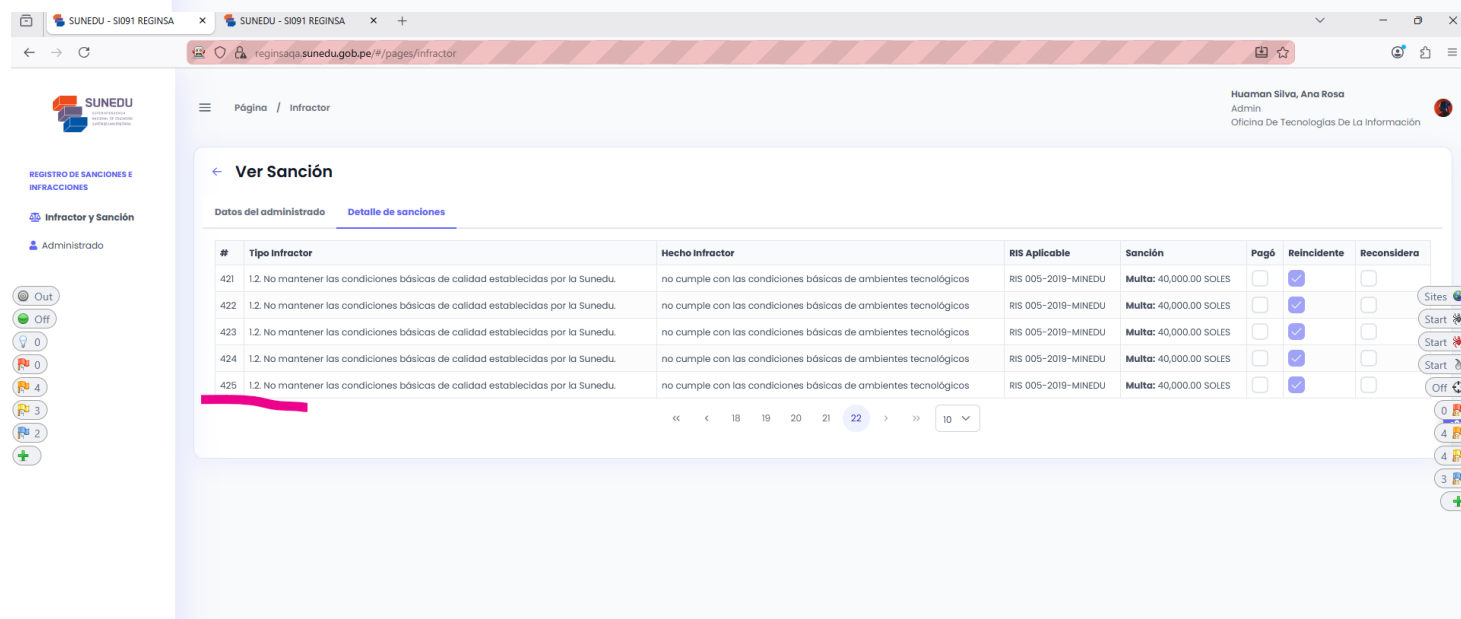
N° de Expediente: R324332

N° de Resolución: 45355

Resolución de Sanción: Archivo: /api/reginsa/16200351-2282-48EA-8EB7-19196BE8F56/16200351-2282-48EA-8EB7-19196BE8F56.pdf

Fecha de Resolución: 02/03/2026

Medidas correctivas: Medida Correctiva 1: accion correctiva 2 iteración



Ver Sanción

Datos del administrado | Detalle de sanciones

#	Tipo infractor	Hecho infractor	RIS Aplicable	Sanción	Pagó	Reincidente	Reconsidera
421	1.2. No mantener las condiciones básicas de calidad establecidas por la Sunedu.	no cumple con las condiciones básicas de ambientes tecnológicos	RIS 005-2019-MINEDU	Multa: 40,000.00 SOLES	☐	☒	☐
422	1.2. No mantener las condiciones básicas de calidad establecidas por la Sunedu.	no cumple con las condiciones básicas de ambientes tecnológicos	RIS 005-2019-MINEDU	Multa: 40,000.00 SOLES	☐	☒	☐
423	1.2. No mantener las condiciones básicas de calidad establecidas por la Sunedu.	no cumple con las condiciones básicas de ambientes tecnológicos	RIS 005-2019-MINEDU	Multa: 40,000.00 SOLES	☐	☒	☐
424	1.2. No mantener las condiciones básicas de calidad establecidas por la Sunedu.	no cumple con las condiciones básicas de ambientes tecnológicos	RIS 005-2019-MINEDU	Multa: 40,000.00 SOLES	☐	☒	☐
425	1.2. No mantener las condiciones básicas de calidad establecidas por la Sunedu.	no cumple con las condiciones básicas de ambientes tecnológicos	RIS 005-2019-MINEDU	Multa: 40,000.00 SOLES	☐	☒	☐

« < 18 19 20 21 22 > » 10

Resultado:

Al realizar la prueba de numeración de 9999 peticiones, se observa que se registraron 425 infracciones
 No se da conformidad

RECOMENDACIÓN:

- Establecer mecanismos de validación de solicitudes, mediante captcha o token o control por número límite de solicitudes y por tiempo.
<http://enterprise.arcgis.com/es/server/latest/administer/linux/enable-token-acquisition-through-an-http-get-request.htm>

<https://webdesign.tutsplus.com/es/tutorials/how-to-integrate-no-captcha-recaptcha-in-your-website--cms-23024>

- Configurar el control de la petición ajustando por tiempo según el caso de creación de una infracción y por cantidad de infracciones creadas según el caso de la necesidad funcional del sistema.

Escaneo dinámico

<https://reginsaapiqa.sunedu.gob.pe>

Alto /

1

Descripción

Se realizó el escaneo dinámico y se tiene las siguientes vulnerabilidades a considerar en el servidor

Impacto

- Más probabilidad de instrucción y hackeo al servidor por vulnerabilidades en el sistema operativo y en software IIS
- Caída de servidor y del servicio ante un ataque.

Sistemas afectados

<https://reginsaapiqa.sunedu.gob.pe>

Recomendación

SUBSANAR LAS VULNERABILIDADES

Alertas

Nombre	Nivel de riesgo	Número de Instancias
Inyección SQL - SQLite	Alto	14

Inyección SQL - SQLite

Evidencia

Z:\03.Seguridad-Calidad\Ethical Hacking\2026\03 Reginsa\iteracion2

Resultado:

Se subsana varias vulnerabilidades
 Se registró una vulnerabilidad
 Pendiente

Escaneo dinámico

reginsaqa.sunedu.gob.pe

/ bajo

Descripción

Se realizó el escaneo dinámico y se tiene las siguientes vulnerabilidades a considerar en el servidor

1

Impacto

- Más probabilidad de instrucción y hackeo al servidor por vulnerabilidades en el sistema operativo y en software IIS
- Caída de servidor y del servicio ante un ataque.

Sistemas afectados

reginsaqa.sunedu.gob.pe

Recomendación

SUBSANAR LAS VULNERABILIDADES

El servidor divulga información mediante un campo(s) de encabezado de respuesta HTTP ""X-Powered-By""

Bajo

20

El servidor filtra información de versión a través del campo "Server" del encabezado de respuesta HTTP

Bajo

20

El servidor divulga información mediante un campo(s) de encabezado de respuesta HTTP ""X-Powered-By""

El servidor filtra información de versión a través del campo "Server" del encabezado de respuesta HTTP

Evidencia

Z:\03.Seguridad-Calidad\Ethical Hacking\2026\03 Reginsa\iteracion2

Resultado:

Se mantiene vulnerabilidad